PROJECT REQUIREMENTS

API Security Framework: Automated OWASP ZAP and Postman Checks for BOLA

1. Hardware Requirements

- Computer capable of running Python and a modern browser.
- 4 GB RAM minimum; 8 GB recommended when running ZAP and other tools together.
- Network access to an explicitly authorized staging API.

2. Software Requirements

- Python 3.10 or newer.
- OWASP ZAP and Postman for complementary testing workflows (optional external applications).
- Code editor or IDE.
- Staging API with two dedicated test identities and synthetic records.

3. Python Dependencies

No third-party Python packages are required. The script uses Python standard-library modules only.

4. Functional Requirements

- Load a JSON test plan of relative API object paths.
- Send GET/HEAD requests with two separate bearer tokens.
- Compare response status codes for owner and alternate identity.
- Produce a JSON report with findings, timestamps, and response fingerprints.
- Avoid storing response bodies or credentials in the report.

5. Security and Ethical Requirements

- Written authorization and defined scope are mandatory.
- Use staging, dedicated test accounts, and synthetic objects.
- Store tokens in environment variables, not source code or Git.
- Do not use the tool to access other users' real data.
- Confirm every potential issue manually; do not treat status codes alone as proof.

6. Acceptance Criteria

- Valid JSON test plans load successfully.
- The script compares responses from two configured identities.
- Invalid or missing tokens are rejected before requests are sent.
- Reports are valid JSON and omit response bodies.
- Potential BOLA signals include an explanation and limitations.

Note: OWASP ZAP and Postman are not bundled or automatically controlled by the Python script. Their configuration and use depend on the authorized test environment.